

Class 31 Phishing Simulation & Analysis For SOC

THM Room : Phishing Analysis Fundamentals

The Email Address

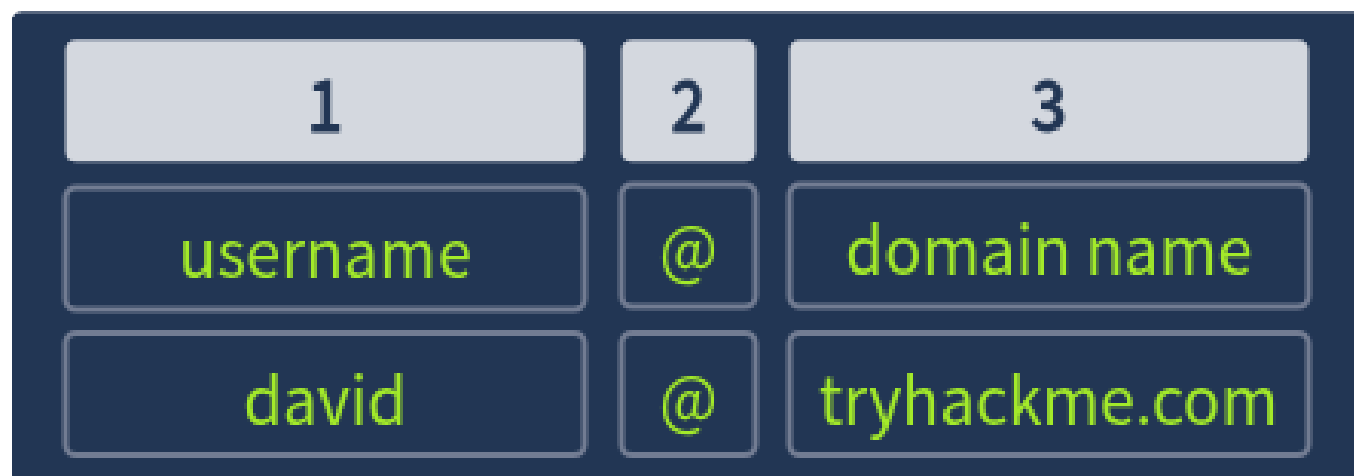
Email as we know it today was popularized in the 1970s on [ARPANET\(opens in new tab\)](#) by Ray Tomlinson, who introduced the @ symbol to separate the user from the destination system.

Anatomy of an Email Address

So what makes up an email address? Let's take a look at the example below, where an email is composed of the following elements:

1. Username: User mailbox that identifies the specific recipient's mailbox on the email server
2. @ symbol: Separates the username from the domain and tells the system where to route the email
3. Domain name: Specifies the mail server responsible for receiving the message

In the last example, the intended recipient username is `david` and the intended recipient domain is `tryhackme.com`.



A helpful analogy is to think of an email address as a home mailing address:

- The **domain** is like the street or apartment building
- The **username** is the specific person or mailbox within that location

With both pieces of information, the postal worker (mail server) knows exactly where to deliver the message.

Email Delivery

When you send an email, several protocols work together behind the scenes to deliver your message from sender to recipient, and each protocol has a specific role:

- **Simple Mail Transfer Protocol (SMTP):** Sends emails
- **Post Office Protocol (POP3):** Downloads emails to a device
- **Internet Message Access Protocol (IMAP):** Syncs emails across devices

When receiving emails, your email service will use either POP3 or IMAP, depending on how your mailbox is configured. Let's take a look at both of these protocols below:

POP3

- Emails are downloaded and stored on a single device
- Sent messages are stored on the single device from which the email was sent
- Emails can only be accessed from the single device to which the emails were sent
- Emails are typically removed from the server after download

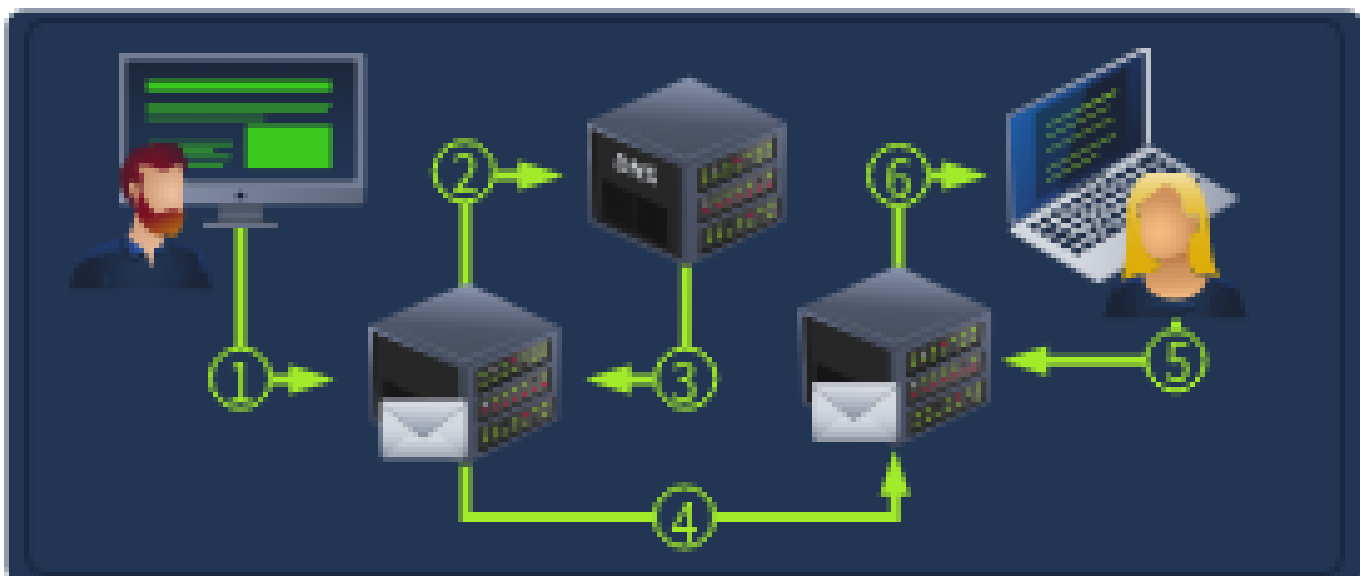
IMAP

- Emails are stored on the server and can be downloaded to multiple devices
- Sent messages are stored on the server
- Syncs messages across multiple devices
- Emails remain on the server unless explicitly deleted

An Email's Journey

Rather than memorizing definitions, it's easier to understand these protocols by following the path an email takes. Let's take a look at a simplified flow through of the journey an email takes from sender to receiver:

1. User sends an email: The sender's email client sends the message to their mail server using SMTP
2. Mail server queries DNS: The sending server asks DNS for the recipient domain's mail server
3. DNS responds: DNS returns the address of the recipient's mail server
4. Email is delivered: The message is sent across the Internet to the recipient's server
5. The recipient checks their mailbox: The recipient's email client connects to their mail server
6. Email is retrieved: The message is downloaded (POP3) or synced (IMAP) to the recipient's device



Email Headers

let's take a closer look at what an email actually contains when it arrives in an inbox. This is especially important when analyzing potentially malicious emails.

An email consists of two main parts:

- **Email header:** Contains metadata about the message, such as sender and the servers involved in delivery
- **Email body:** Contains the actual message content, which may be plain text or HTML

Email Headers

Let's take a look at the different components that make up an email header.

1. **From:** The sender's email address
2. **To:** The receiver's email address
3. **Reply to:** Address where replies are sent (not required)
4. **Subject:** The email's subject line
5. **Date:** The time and date that the email was sent



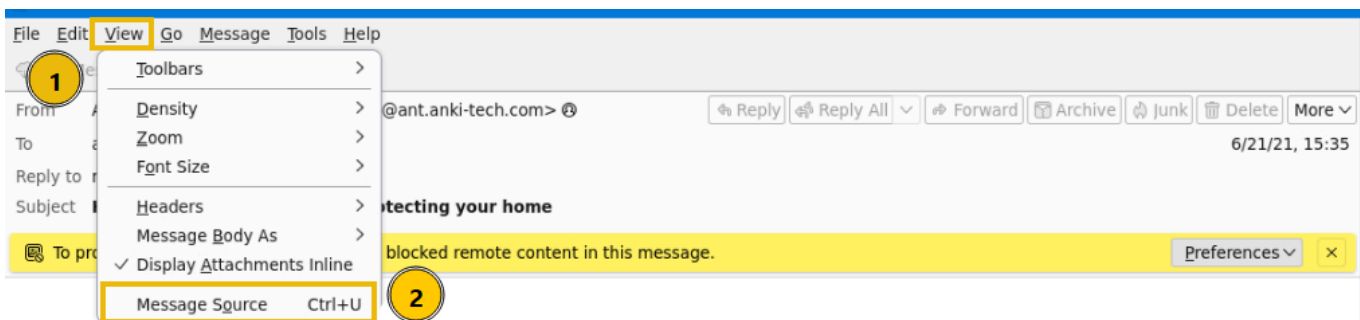
Viewing the Message Source

Another method to obtain the same email header information, and more, is by viewing the raw message data. Viewing the email source displays the full raw message, including all header fields and the email body, which may contain plain text or HTML. It also reveals technical details not visible in the standard inbox view.

Ensure you're viewing the `email1.eml` sample in Thunderbird mail in your VM instance:

1. Navigate to the View menu
2. Choose Message Source

This can also be accomplished with the shortcut `ctrl + u`.



Let's take a look at the snippet of the raw message from the `email1.eml` file. You can see in the screenshot below that we have a wealth of information available to us for analysis, including the originating IP address and full email header details. Let's use this information to answer the task's questions below.

Received: from [redacted] (EHLO smtp3-160.piican.com)
by 10.222.142.150 with SMTP;
Mon, 21 Jun 2021 15:36:02 +0000
DKIM-Signature: a=rsa-sha256; bh=TQXVGyjb6bIRm7BASwSHB6HSI0KKcsmmgRm0n9HHo=;
c=relaxed/relaxed; d=ant.anki-tech.com;
h=Subject:From:To:Sender:Reply-To:Date:List-Unsubscribe:X-CampaignID:Message-ID:X-Mailer-Info:MIME-Version:Content-Type;
s=default; t=1624289739; v=1;
b=DLxYfx9u4fxp918X8lTCay4atskJfkc15d3ygf5hsz1Yv3SynxMbN1e0xTG/jgK1WcxZkUqN
lUzgbaGhP62B1v2PvwA45trwdbiJ08wWv9KtsUc41nQCXJXGLtdE876ffdH9PQTF8n2ayDe0tb/
58eeVz2h0uaP57hBzKx3IC3U=

Subject: Help protect your budget by protecting your home
From: "ADT Security Services" <newsletters@ant.anki-tech.com>
To: alexa@yahoo.com
Sender: newsletters@ant.anki-tech.com
Reply-To: reply@ant.anki-tech.com
Date: 21 Jun 2021 15:35:39 -0000

Originating IP Address

Email Header Details

Email Body

As mentioned in the previous task, the body of an email contains the message. Emails are sent as text only or formatted in HTML. HTML supports elements such as images, links, and styling. Most email clients show you the rendered content. You can also inspect the underlying source to see how the message is structured, spot embedded elements, and look for signs of phishing or malicious content.

Hello Dave,

I hope you had a great holiday and weekend.

When you get a chance, could you please send over the Q1 finance report?

Thank you,

Steven - Accounting



URGENT: CLOUD ACCESS SUSPENDED

Access to your cloud services has been revoked. A failed billing verification caused an immediate suspension of critical cloud protections.

Accounts without active protection are exposed to **unauthorized access, data extraction, credential theft, and permanent data loss.**

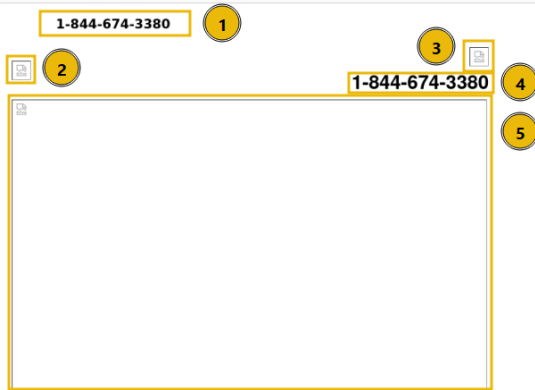
Text Based Email

HTML Formatted Email

Viewing HTML Source Code

Just as we can inspect an email's source to analyze its headers, we can also examine the source of the email body. This allows us to see the raw HTML that renders the message. Let's compare the rendered version of the `email1.eml` message with its underlying HTML. You may notice that some images are not displayed because Thunderbird blocks them by default. By viewing the raw source, we can clearly see how these HTML elements are structured behind the scenes, giving us a closer look at links, images, and other embedded content that may not be immediately visible in the rendered view.

From: ADT Security Services <newsletters@ant.anki-tech.com>
To: alexa@yahoo.com @
Reply to: reply@ant.anki-tech.com
Subject: Help protect your budget by protecting your home



Rendered HTML

```
<title>ADT</title>
</head>
<body>
<p><a style=3D"text-decoration: none; color: #000000; margin-left: 180px;" =
href=3D"tel:1-844-674-3380"><strong>1-844-674-3380</strong></a></p>
<table width=3D"600" align=3D"center">
<tbody>
<tr>
<td rowspan=3D"2" align=3D"left"><a href=3D"https://ant.anki-tech.com/ga/cl=
ick/2-952622232-3970-423304-838253-590962-350694bcf9-17b3b9c21a"><img src=
=3D"http://blueoceanfresh.com/img/15ef9a655495d9455ef32e9cfd0b49e6" /></a><=
</td>
<td align=3D"right"><a href=3D"https://ant.anki-tech.com/ga/click/2-9526222=
32-3970-423304-838253-590962-350694bcf9-17b3b9c21a"><img src=3D"http://blue=
oceanfresh.com/img/15ef9a655495d9455ef32e9cfd0b49e6" /></a></td>
</tr>
<tr>
<td align=3D"right" colspan=3D"2" style=3D"font-family: Helvetica, Arial, Sans-Serif; =
text-align: right; color: #000000; font-weight: normal; font-size: 24px; wo=
rd-break: keep-all;" align=3D"right" valign=3D"top"><a style=3D"text-decora=
tion: none; color: #000000;" href=3D"tel:1-844-674-3380"><strong>1-844-674-
3380</strong></a></td>
</tr>
<tr>
<td colspan=3D"2"><a href=3D"https://ant.anki-tech.com/ga/click/2-952622232=
-3970-423304-838253-590962-350694bcf9-17b3b9c21a"><img src=3D"http://blueoc=
eanfresh.com/img/15ef9a655495d9455ef32e9cfd0b49e6" width=3D"592" height=3D"=
1001" border=3D"0" /></a></td>
</tr>
</tbody>
</table>
<table width=3D"620" align=3D"center">
<tbody>
<tr align=3D"justify">
```

Raw HTML

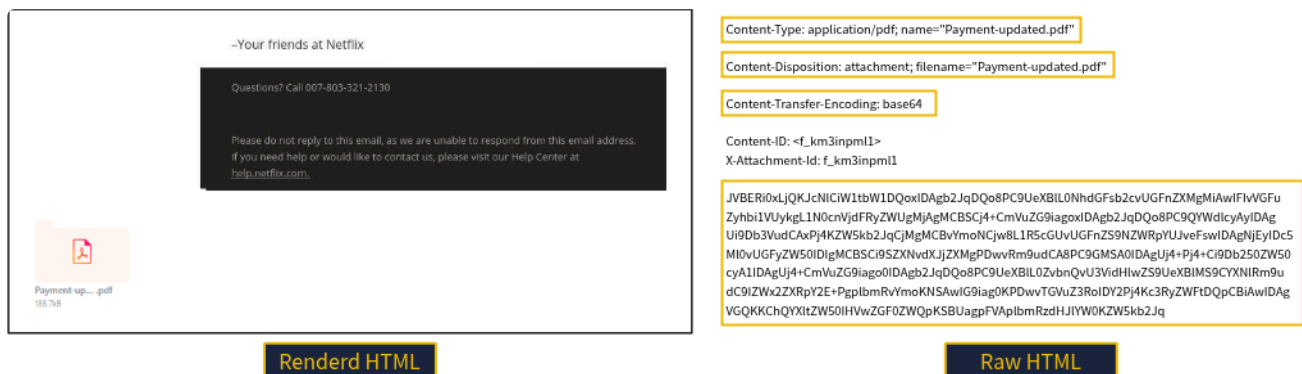
Reconstructing Attachments

Emails can also include attachments, such as documents, images, or other file types. Just as the email body can be analyzed by viewing the message source, attachments can be analyzed as well. This allows us to understand how the file is embedded within the email.

In the example below, you'll see an HTML-formatted email containing a PDF attachment. The rendered view shows the attachment as it appears in the email client, while the source view shows how it is actually stored within the message. When we inspect the source, we can identify several important headers associated with the attachment:

- **Content-Type** indicates the file type `application/pdf`
- **Content-Disposition** specifies that the file is an attachment and includes its filename
- **Content-Transfer-Encoding** shows that the file is `base64` encoded

The encoded base64 that follows represents the file itself. This data can be decoded to reconstruct the original attachment using either [CyberChef\(opens in new tab\)](#) or a base64 to PDF [converter\(opens in new tab\)](#).



Type Of Phishing

In this task, we'll explore the different types of malicious emails and the techniques attackers use to make them appear legitimate. By understanding these patterns, you'll be better equipped to identify suspicious messages and avoid common phishing traps before they compromise your systems. Different types of malicious emails can be classified as one of the following:

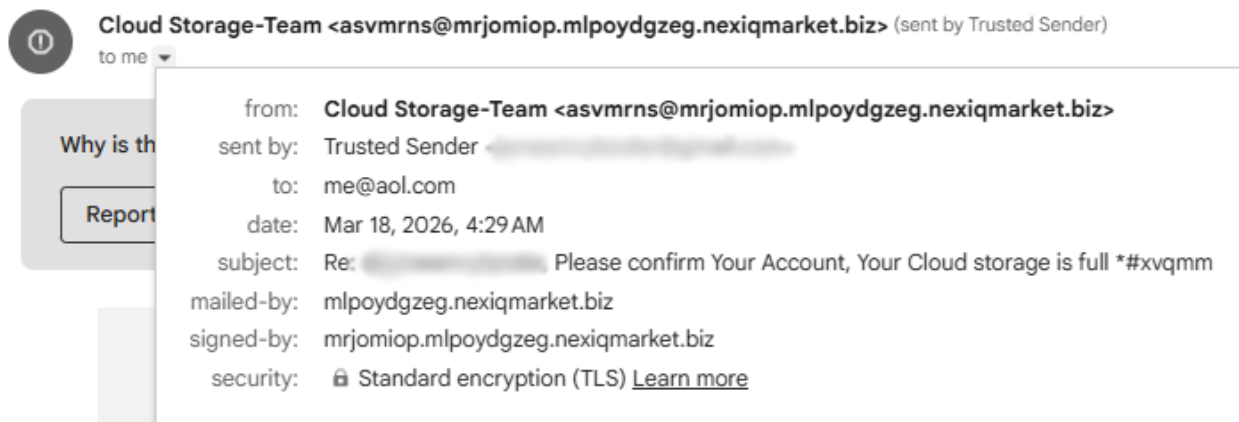
- [Spam\(opens in new tab\)](#): Unsolicited bulk emails sent to a large number of recipients. A more malicious form of spam is often called malspam.
- [Phishing\(opens in new tab\)](#): Emails that impersonate a trusted entity to trick recipients into revealing sensitive information.
- [Spear Phishing\(opens in new tab\)](#): A targeted form of phishing aimed at a specific individual or organization, often using personalized information.
- [Whaling\(opens in new tab\)](#): A type of spear phishing that specifically targets high-level executives (CEO, CFO) to obtain sensitive data or financial access.
- [Smishing\(opens in new tab\)](#): Phishing attacks conducted via SMS or text messages, targeting users on mobile devices.
- [Vishing\(opens in new tab\)](#): Phishing attacks carried out through voice calls, where attackers use social engineering over the phone.

Anatomy of a Phishing Email

When it comes to phishing, attackers often rely on similar techniques regardless of their goal. Their objective may be to harvest credentials, deliver malware, or gain unauthorized access to a system, but the methods used to trick the recipient are often the same.

Below are some common characteristics of phishing emails:

- **Spoofed From Address:** The sender's email is spoofed to appear as a trusted entity (noreply@microsoft.com)
- **Urgent Subject or Message:** The email creates a sense of urgency ("Your account will be locked in 24 hours")
- **Brand Impersonation:** The email is designed to mimic a legitimate organization (logos or colors matching a real company)
- **Grammar & Spelling Issues:** The message may contain errors, though with AI these are now less common (awkward phrasing or unnatural wording)
- **Generic Content:** The message lacks personalization ("Dear Customer" instead of your name)
- **Hidden or Shortened Links:** Hyperlinks may disguise their true destination (bit.ly/secure-login)
- **Malicious Attachments:** Attachments are included and disguised as legitimate files (invoice.pdf.exe)



CLOUD STORAGE

Last Notice:

Your account will be locked within 48 hours. Your storage capacity is full!

Account ID	Email	Status	Renewal Discount
29645041US		Storage is Full	50GB

You can continue backing up your photos with extra cloud storage!

Receive 50 GB

Safe Analysis

When dealing with hyperlinks and attachments, be careful not to click them accidentally. [Hyperlinks\(opens in new tab\)](#) and [IP addresses\(opens in new tab\)](#) should be **defanged**. Defanging makes URLs, domains, or email addresses unclickable to prevent accidental clicks that could lead to a security breach. It works by replacing special characters, such as @ in an email or . in a URL, with alternate characters:

- Original URL: `http://www.suspiciousdomain.com`
- Defanged URL: `hxxp[:]//]www[.]suspiciousdomain[.]com`

THM Room : Phishing Emails in Action

Cancel Your Order

In this task, we will examine a sample email designed to mimic an official transaction receipt from PayPal. By analyzing this specific sample, we will focus on how attackers leverage spoofed email addresses to impersonate trusted services and the strategic use of URL shortening services to obfuscate the final destination of malicious links.

Phishing Techniques Used

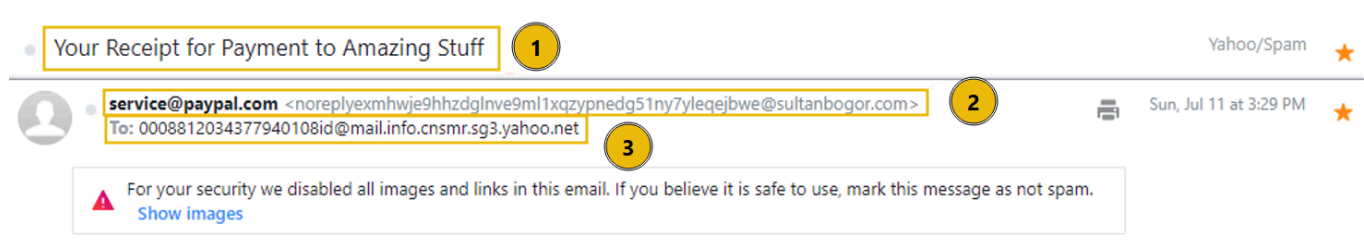
- **Spoofed email address:** Mimicking a trusted service to gain immediate credibility
- **URL shortening:** Using redirection services to hide the true destination of a link
- **Branded HTML:** Impersonating legitimate corporate imagery to create a sense of authenticity

First Observations

Let's first look at the sample email header and take a few notes on our immediate observations.

1. **Attention-grabbing subject line:** The subject line uses a fake transaction to create a sense of urgency, prompting you to react in haste
2. **From address:** This is an immediate red flag as the sender details `service@paypal.com` do not match the actual address `gibberish@sultanbogor.com`

3. **To address:** This is an unusual email recipient address and not a normal Yahoo domain



Email Body Analysis

Taking a look at the email body below, we can see that this is a receipt for a purchase of gift cards. The email is designed to appear as a legitimate email from PayPal. There aren't any attachments associated with this email, and the only interactive element in this email is the **Cancel the order** button. Let's take a closer look.

Sun, July 11, 2021 9:29 PM
Transaction ID: 74221905U

Hello Customer,

You sent a payment of \$120.00 USD to Amazing Stuff
(helpcenter@██████████.com)

Charge will appear on your credit card statement as "PAYPAL "WORLDGIFT"
Payment sent to helpcenter@██████████.com

Funding Sources Used (Total)
Credit Card \$120.00 USD

It may take a few moments for this transaction to appear in your account.

Merchant
Amazing Stuff
helpcenter@██████████.com
899-552-██████████

Instructions to merchant
You haven't entered any instructions.

Email address - confirmed
ppmxdrilling██████████@██████████.com

Shipping details
The seller hasn't provided any shipping details yet.

Description	Unit price	Qty	Amount
Amazing Stuff Gift Card (EMAIL DELIVERY) Item# 1123685	\$30.00 USD	4	\$120.00 USD
Subtotal			\$120.00 USD
Total			\$120.00 USD
Payment			\$120.00 USD

Cancel the order

Cancel Order Button
Issues with this transaction?

You have 180 days from the date of the transaction to open a dispute in the Resolution Center.

Questions? Go to the Help Center at www.paypal.com/help.

Please do not reply to this email. This mailbox is not monitored and you will not receive a response. For assistance, log in to your PayPal account and click **Help** in the top right corner of any PayPal page or please contact us toll free at 1-888-221-1161.

You can receive plain text emails instead of HTML emails. To change your Notifications preferences, log in to your account, go to your Profile, and click **My settings**.

Copyright © 1999-2021 PayPal, Inc. All rights reserved. PayPal is located at 2211 N. First St., San Jose, CA 95131.
PayPal PPX001066:1.1:c9779baffc706

Button Investigation

By inspecting the raw source of the email, we can further investigate the hyperlinks and underlying HTML that form the message. The **Cancel the order** button leads to the shortened URL. Because the attacker is using a URL shortening service, the final destination is obfuscated, making it impossible to verify the landing page at a glance. As a rule of thumb, you should never interact with buttons or links without first confirming exactly where they lead.

```

<!-- CTA text 17/21 -->
<td bgcolor="#0070BA" align="center" valign="middle" style="padding:13px
90px 13px 90px; display: block; color:#ffffff !important; text-decoration:none; white-space: nowrap;
-webkit-print-color-adjust: exact; display: block; font-family:Calibri, Trebuchet, Arial, sans serif;
font-size:17px; line-height:21px; color:#ffffff !important;border-radius:25px;" class="ppsans
mobilePadding9"><a type="Link" isLinkToBeTracked="true" target="_blank"
linkId="e854f9fff3d47fb841257f9bebb4d1b6" style="text-decoration:none;color:#ffffff !important;
white-space: nowrap;" href="https://is.gd/6oCJ4m?#-u7g?ah7Je1"Cancel the order</a></td>
<!-- end CTA text --></tr>

```

Thankfully for us, there are some great online tools, such as [WhereGoes\(opens in new tab\)](#), that can be used to investigate shortened URLs without having to actually visit the destination.

<https://is.gd/6oCJ4m>

Expand

Screenshot of the distant page behind your short URL



Track Your Package

The next email we will investigate mimics a formal shipping notification to trick recipients into a sense of urgency. By analyzing this sample, we will uncover how attackers use spoofed addresses, link manipulation, and tracking pixels to compromise users. We'll also examine the raw source code to see why email providers flagged these specific red flags.

Phishing Techniques Used

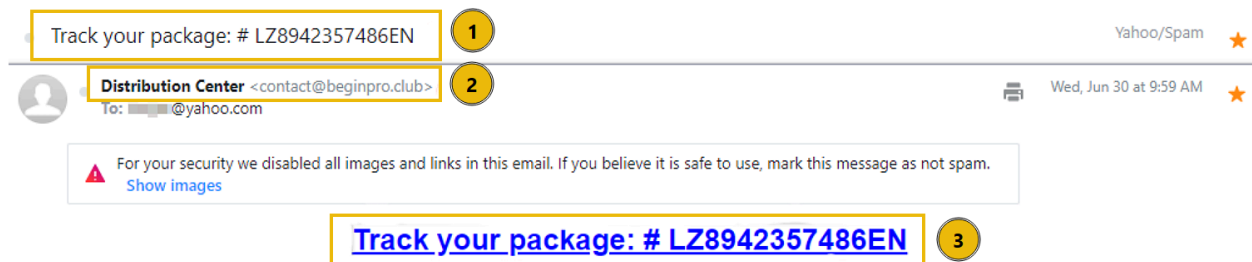
- **Spoofed email address:** Mimicking a trusted distribution center to gain immediate credibility

- **Pixel tracking:** Embedding invisible images to notify the sender when the email is opened
- **Link manipulation:** Masking a malicious destination with a fraudulent tracking number

First Observations

Let's take a look at the email below and try to highlight our initial observations.

1. **Subject line:** The subject line uses a fake tracking number to create a sense of urgency, prompting the recipient to click to see their package status
2. **From address:** This is an immediate red flag, as the display name **Distribution Center** does not match the actual sender address `contact@beginpro.club`
3. **Hyperlink:** The link in the email body matches the subject line, although we do not know where it directs to just yet



Note that in this email sample, Yahoo blocked the images from automatically loading. Any guesses as to why? Typically, you can hover the cursor over a link to see where the link is pointing to, but in this sample, that technique won't work because Yahoo disabled links in the email. We can look at the raw source code for the email and find out.

Hyperlink Tracking

Let's check out the source of the email message to get a closer look at the tracking number hyperlink from above. Here is an image file named `Tracking.png`. These trackers send information back to the spammer's server. There are several reasons spammers embed [tracking pixels\(opens in new tab\)](#) (very small images) into their emails, and now we can understand why Yahoo automatically blocked the images in this email. Many email providers do the same.

```

<html>
<body>
  <center>
    <a style="color:#000000" href="http://devret.xyz/4833mt11254939vf6888zq22032si1269du1508rr" >
      <font color=indianred size=5 face=Rockwell> <FONT color="#0000FF" face="arial" size=5 ><strong>
        </FONT><br/><br/>
      </a>
      <br />
      
      <map name=" grmk"><br />
        <area shape="rect" coords="0, 0, 1500, 1400" href="http://devret.xyz/4833fx11254939ea6888wk22032mk1269ep1508rr" >
      </map>
      <br />
      
      <map name="unsub">
        <area shape="rect" coords="0, 0, 1500, 1400" href="http://devret.xyz/4833jo11254939iz6888xo22032gu1269jm1508uu" >
      </map>
      <br />
    </center>
  </body>
</html>



```

Diagram labels in the image:

- Hyperlink Destination**: Points to the href attribute of the first <a> tag.
- Tracking Pixel**: Points to the src attribute of the first tag.
- Display Text**: Points to the text content of the first <a> tag.
- Track your package: # LZ8942357486EN**: Points to the href attribute of the first <area> tag inside the first <map>.

Download Document Here

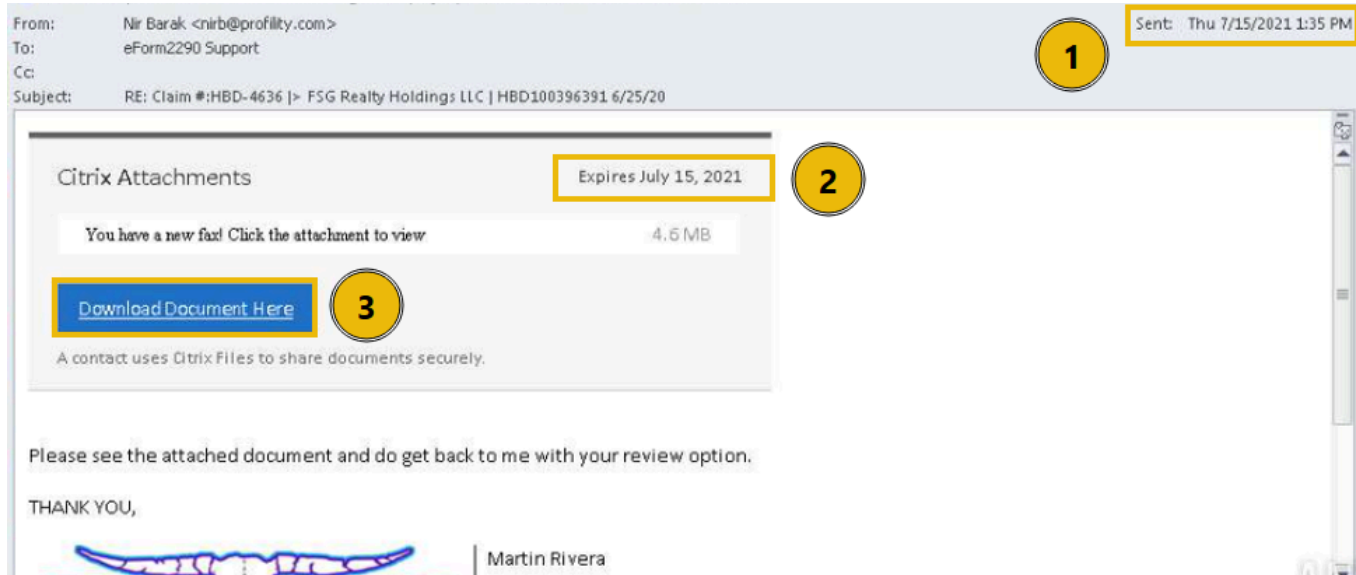
In this task, we will analyze a [phishing campaign\(opens in new tab\)](#) that utilizes a multi-stage redirection chain to harvest user credentials. This sample demonstrates how attackers leverage the reputations of professional document-sharing services, such as OneDrive, Adobe, and Microsoft, to create a deceptive path that leads the victim to a fraudulent login portal.

Phishing Techniques Used

- **Artificial urgency:** Creating a narrow window for action to create a sense of urgency
- **Brand impersonation:** Layering trusted brands, like Microsoft and Adobe, to build a false sense of security
- **Link redirection:** Using a chain of URLs to hide the final malicious destination from basic email filters
- **Credential harvesting:** Deploying a fake login portal to capture and exfiltrate usernames and passwords

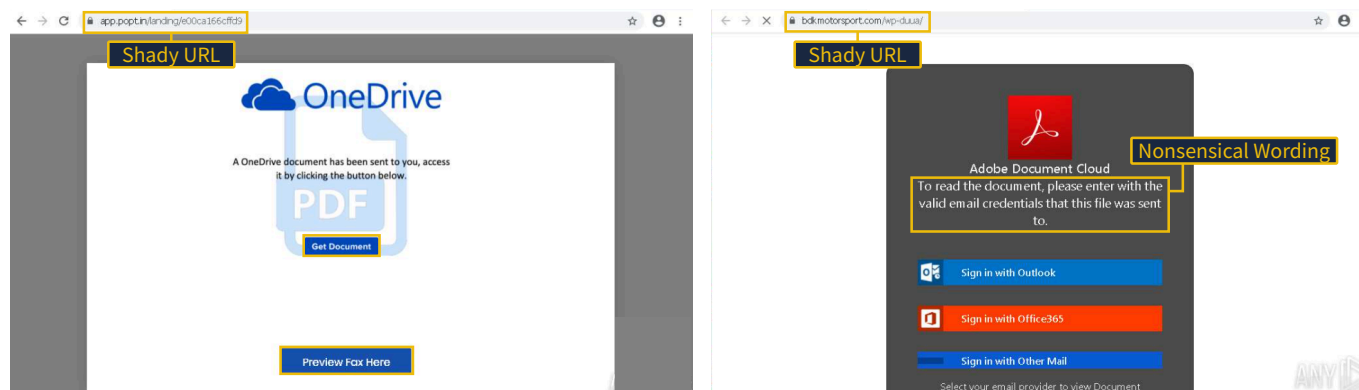
First Observations

1. **Send date:** The email was sent on Thursday, July 15th, 2021
2. **Expiration date:** A sense of urgency is introduced in this email. Notice that the link to download the fax document expires on the same day
3. **Download Document Here button:** There is an action to perform. In this case, a button to download the fax



Download Document Here

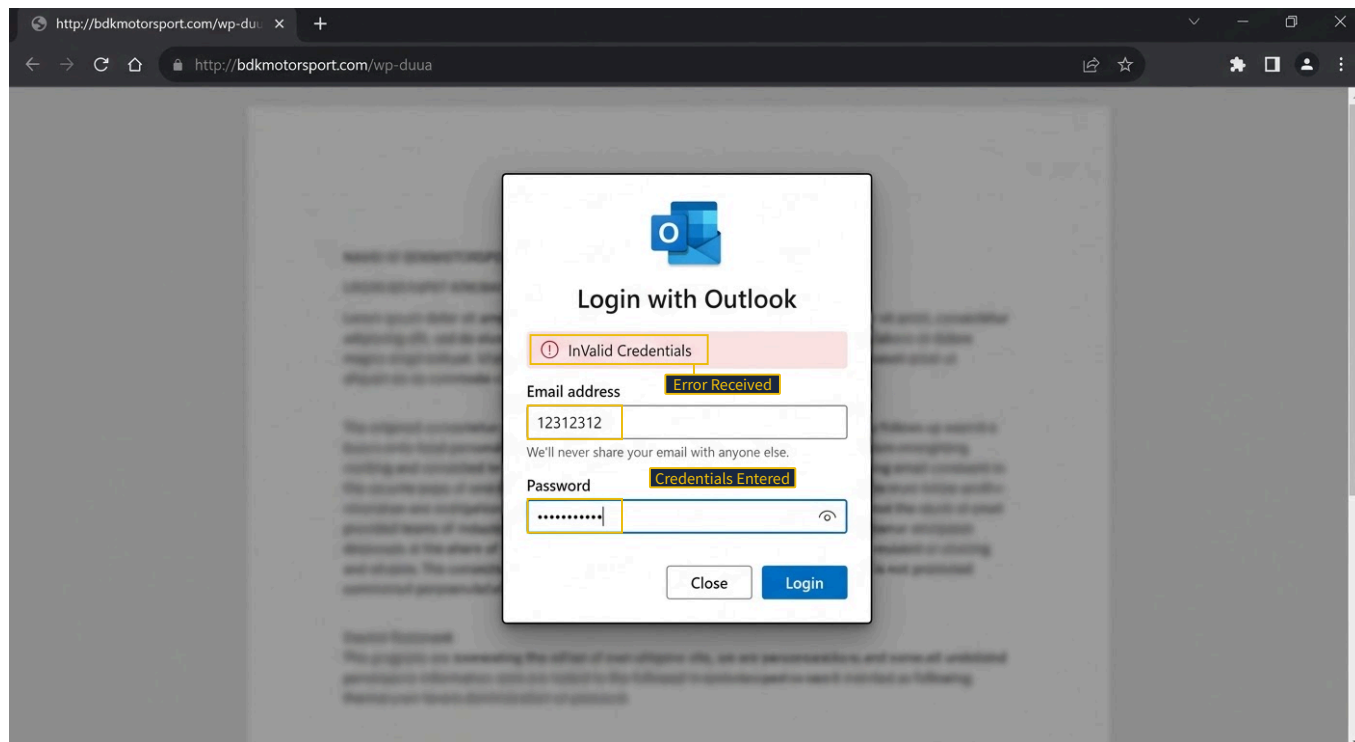
After clicking the `Download Document Here` button, the user is redirected to a landing page that mimics a legitimate OneDrive share. Interacting with the buttons on this page triggers a second redirection to a site impersonating Adobe, though several critical red flags are apparent. The URL is highly suspicious, and the provided directions are nonsensical. These inconsistencies lead to the final trap: a credential-harvesting portal that asks the victim to sign in with their email provider to view the document.



Logging In

In this example, the victim attempts to log in using Outlook. Even if they had entered valid credentials, the result would be the same: a generic error message. This happens because the page isn't actually authenticating the user to their mail service; it's simply a front used to send the credentials directly to the attacker's server. While this specific sample has obvious formatting and grammatical issues, keep in mind that these tells are becoming less reliable. With the

help of AI, attackers can now easily generate polished, error-free content, making it harder to spot a scam based on typos alone.



Your Account is On Hold

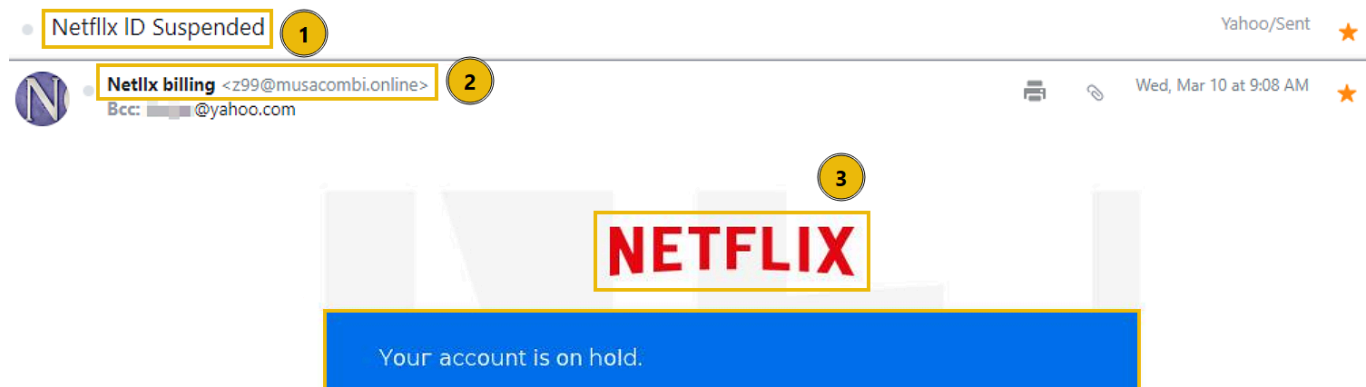
In this example, we will again examine an email claiming to be from a trusted, household brand that demands immediate action from the recipient. While previous cases may have relied on malicious links, this variant introduces a shady attachment. By masquerading as an official billing notification, the attacker attempts to bypass standard email filters and leverage the victim's sense of urgency.

Phishing Techniques Used

- **Spoofed email address:** The sender's display name is set to **Netllx billing** to appear legitimate
- **Sense of urgency:** Using a suspended account notification to pressure the victim into acting quickly
- **Brand impersonation:** Utilizing HTML templates and logos to mimic Netflix billing
- **Poor grammar and typos:** Noticeable misspellings of Netflix
- **Attachments:** Using a file attachment rather than a direct link to hide the malicious URL

First Observations

1. **Email subject:** The receiver's ID was suspended and must act quickly
2. **From address:** The display name does not match the user and domain
3. **Brand impersonation:** The email utilizes rendered HTML to impersonate Netflix



Email Body and Attachment Analysis

Taking a look at the email body, we can see that the user is informed that there is an issue with their billing information. In order to update their account, they must open the attached PDF file. The attachment contains an embedded link titled `Update Payment Account` which directs to a URL not associated with a legitimate Netflix domain. We will investigate this email in detail in the next room of this module, [Phishing Analysis Tools](#). There are a couple other of points of interest worth noting.

1. The use of an atypical phone number format is a red flag
2. Using a legitimate Netflix help center domain to build a false sense of trust

Please update your payment details

Hello Customer,

We're having some trouble with your current billing information. Please open file (PDF) to update your account.

Need help? We're here if you need it. Visit the Help Center or contact us now.

~Your friends at Netflix

Questions? Call 007-803-321-2130 (1)

Please do not reply to this email, as we are unable to respond from this email address. If you need help or would like to contact us, please visit our Help Center at help.netflix.com.

Update Payment Account

If you did not ask to reset your password you may want to review your [recent account access](#) for any unusual activity.

We're here to help if you need it. Visit the [Help Center](#) for more info or [contact us](#).

- Your friends at Netflix

(2)

Email Body

PDF Attachment

Your Recent Purchase

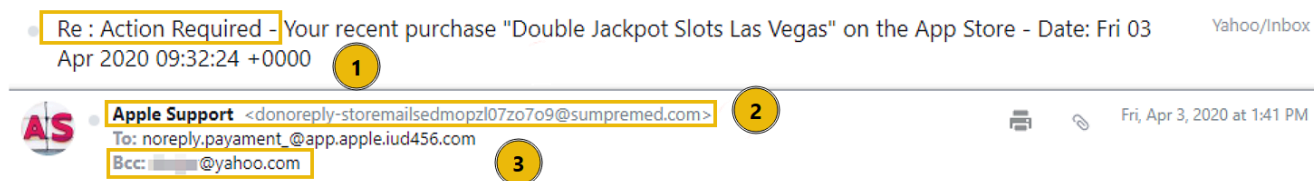
In this example, we will analyze a phishing attempt that masquerades as a billing notification from a major service provider. Unlike previous tasks that relied on body text to lure the victim, this sample utilizes a completely blank email body, and relies solely on a suspicious attachment. We will examine how attackers use BCC fields and spoofed domains to hide the true recipient list while leveraging a sense of urgency to trick the user into opening a malicious file.

Phishing Techniques Used

- **Spoofed email address:** The sender's display name is set to **Apple Support**
- **Recipient is BCCed:** The victim is not directly sent the email
- **Urgency:** Relies on the use of **Action Required** and a fake purchase notification
- **Poor grammar and typos:** Noticeable spelling errors within the email header
- **Attachments:** The email contains a [.dot\(opens in new tab\)](#) file (Microsoft Word Template), which is an unusual format for a receipt

First Observations

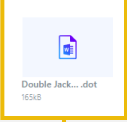
1. **Email subject:** The recipient is told they must act quickly to resolve an unauthorized purchase, creating a false sense of urgency
2. **From address:** The display name, **Apple Support**, does not match the user and domain. There are also typos in the From and To addresses
3. **Blind Carbon Copy:** The recipient was not directly emailed, instead [Blind Carbon Copied\(opens in new tab\)](#) (BCC)



Analyzing the Attachment

The body of the email is completely blank, which is suspicious on its own. The only content present is an attachment in the form of a `.dot` file, so let's investigate further. When the user interacts with the large image embedded in the document, they are redirected to a phishing site. Although the URL includes familiar terms

like **apps** and **ios** to appear legitimate, its excessive length and complexity are strong indicators of a malicious redirection attempt.



Double Jack....dot
155kB

Attachment

Redirect Link

<https://tumblr.com/redirect?z=https://apps.ios-games.mansiiea.com/?njhdhw10d&t=zmm3mgu4nmfmjvknzbjodg1mde2nzfhnmj0nzdtkodnmzmhlmzjsoxhmdrlmtc5y2njnminndcwyzzyzgyzjnzjzjmjmotc2mtk2mzlm>
Ctrl + Click to follow link

Save 3% on all your Apple purchases with Apple Card. Apply and use in minutes.

APPLE ID: example@appleid.com DATE: Apr 03, 2020 ORDER ID: MN HLSF 45X G

DOCUMENT NO.: 137320441420 BILLED TO: [123 Pine St., Springfield, IL 62704, USA]

App Store

Product Icon	Product Details	Price
	Title: Double Jackpot Slots Las Vegas, Large pack of coins Type: In-App Purchase Device: iPhone	\$14.99

[Report a Problem](#)

Large Image

Scheduled Shipment

In this example, we analyze a phishing attempt that masquerades as a global shipping notification using spoofed addresses and branded HTML to appear legitimate. We will examine how the attacker funnels the victim toward a malicious Excel attachment designed to execute a hidden payload.

Phishing Techniques Used

- **Spoofed email address:** The sender's display name is set to DHL Express
- **Brand impersonation:** Utilizing HTML templates and logos to mimic DHL
- **Attachments:** An Excel document that triggers executable code upon opening

First Observations

1. **Email subject:** Gives the impression that DHL will be shipping a package
2. **From address:** The display name, **DHL Express**, does not match the user and domain
3. **Brand impersonation:** The HTML in the email body is designed to look like it is sent from DHL



DHL Express <info@glamcarcompany.de>

To: [REDACTED]



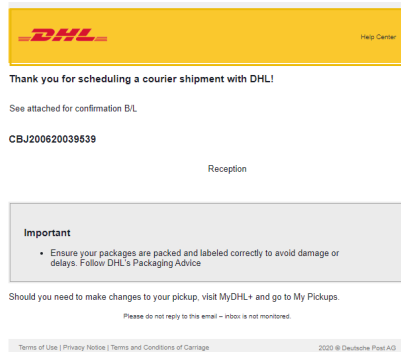
Tue, Jun 30, 2020 at 7:01 PM

[To view this email as a web page, go here](#)[Help Center](#)

Thank you for scheduling a courier shipment with DHL!

Email Body and Attachment

While there isn't much depth to the email body, the meat of this phishing attempt lies in the attached `.xlsx` file. Opening the document reveals several glaring inconsistencies. First, the sender uses a German domain, the invoice is addressed to a city in India, yet the document content itself contains Mandarin. These conflicting geographical markers are classic red flags that should make us question their legitimacy. The document contains a single clickable link designed to move the attack to the next stage.

**XLSX Attachment**

A	B	C
To:	MENON AND MENON LIMITED Wanmangar, KOLHAPUR	TO TRANSLATE LANGUAGE KINDLY CLICK ENABLE EDITING ABOVE Hyperlink
表头:		供应商APPRISAL表格 Ref. No. PURNA/F34
1	姓名和地址	
	公司事务所	
	电话号码	
	传真号码	
	电子邮箱	
1	设立日期	
2	所有者及董事 M.D.	
3	重要的对应主要人物	
4	股东人	
6	我市场的场域	

The Executable

When the link within the Excel document is clicked, it attempts to download and execute a malicious payload named `regasms.exe`. As seen in the screenshot, this execution results in a system error. While the error prevents the payload from running in this environment, it indicates the attacker's intent to execute code directly on the victim's machine.

If successfully executed, the attacker could:

- **Establish Persistence:** Create a backdoor or scheduled task to maintain access after a reboot
- **Exfiltrate Data:** Steal sensitive files, credentials, or browser-stored passwords
- **Deploy Ransomware:** Encrypt the system and demand payment for recovery

